

CYBERSECURITY

LAB7a: Session Hijacking with Caido

D.E. MENACER (CEH)

Copyright © ESI – 2026

SESSION HIJACKING PHASES

- **Tracking the Connection:** The attacker uses a network **sniffer** to track a victim and host, or uses a tool such as **nmap** to scan the network for a target with a TCP sequence that is easy to predict
- **Desynchronizing the Connection:** A desynchronized state occurs **when a connection between the target and host has been established**, or when the **server's sequence number is not equal to the client's acknowledgment number** (or vice versa)
- **Injecting the Attacker's Packet:** Once the attacker has interrupted the connection between the server and target, they can either **inject data** into the network or **actively participate as the man-in-the-middle**, passing data between the target and server, while reading and injecting data at will.

SESSION HIJACKING

- Session hijacking can be either active or passive, depending on the degree of involvement of the attacker:
 - **Active session hijacking:** An attacker finds an active session and takes it over
 - **Passive session hijacking:** An attacker hijacks a session, and, instead of taking over, monitors and records all the traffic in that session

HIJACK A SESSION USING CAIDO

- **Caido** assists security professionals and enthusiasts in efficiently **auditing web applications**.
- It offers exploration tools, including **sitemap**, **history**, and **intercept features**, which aid in **identifying vulnerabilities** and analyzing requests in **real-time**.
- Users can modify **incoming requests** using **Forward and Tamper tools**, enhancing testing customization and system security comprehension.
- **Automation** is facilitated through the **Automate tool**, allowing for *faster* vulnerability discovery by **testing requests against large wordlists**.
- **Here, we will use Caido to perform session hijacking on the target machine.**

LAB: CAIDO

- You need the following VMs:
 - Windows 11
 - Windows Server 2019
 - Windows Server 2022
 - Parrot Security virtual machine
- Web browsers with an Internet connection
- Administrator privileges to run the tools
- **Note:** Before starting, we need to configure the proxy settings in the victim's machine, which in this task will be the Windows Server 2019 machine.

Gathering information

- Collect all information about VMs:
 - IP address
 - DNS
 - Gateways
 - Hostname/Domain
 - Installed softwares
 - OS
 - Open ports/Services

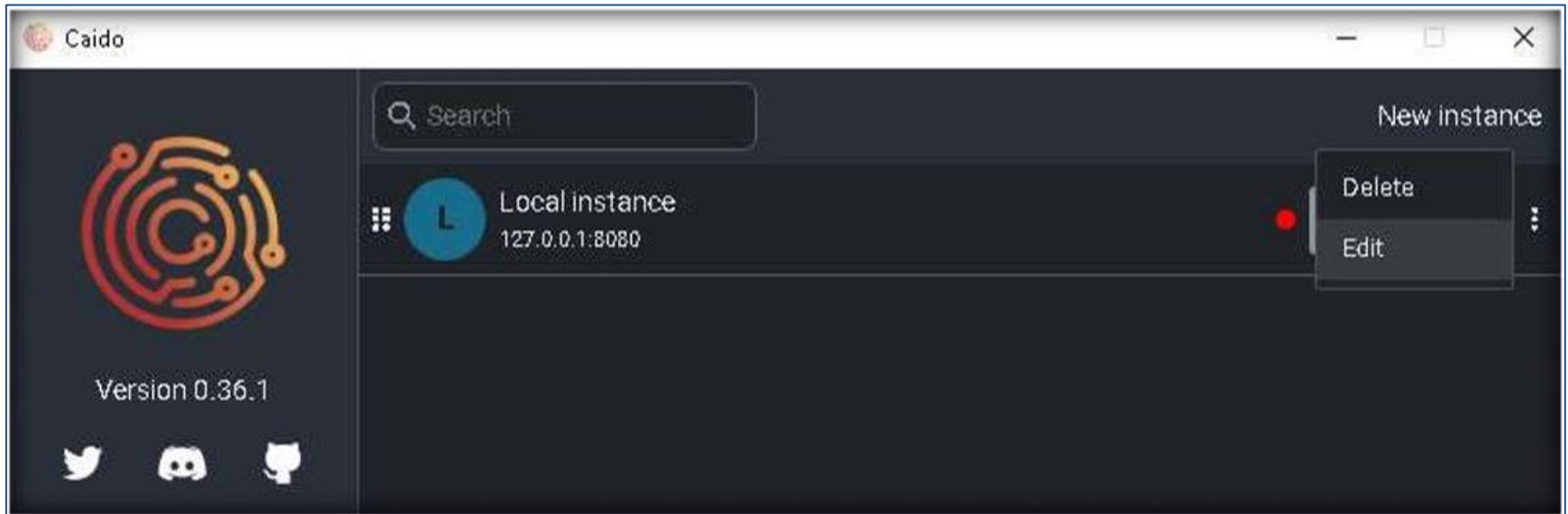
LAB PREPARATION

1. Turn on the **Windows 11** and **Windows Server 2019** virtual machines.
2. Switch to the **Windows 11** machine. Login using **Admin/Pa\$\$w0rd**.
3. Click windows Search icon on the Desktop, search for **cmd** and launch Command Prompt from search bar.
4. Run **ipconfig/flushdns** command to reset **DNS cache** and close the Command Prompt.

LAUNCHING CAIDO

4. Click windows Search icon on the Desktop, search for **Caído** and launch Caído from search bar.
5. **Caído** application window appears, click on menu besides Start button and select Edit.

CAIDO WINDOW



7. In **Edit Instance window**, click on the radio button besides All interfaces (**0.0.0.0**) to listen on all the available network interfaces and click on **Save**.

Edit Instance window

Caïdo

Edit Instance Cancel



Version 0.36.1

Name

Local instance

Listening address

☐ Localhost (127.0.0.1)

☒ All interfaces (0.0.0.0)

☐ Custom

Listening port

8080

> Advanced

Send feedback

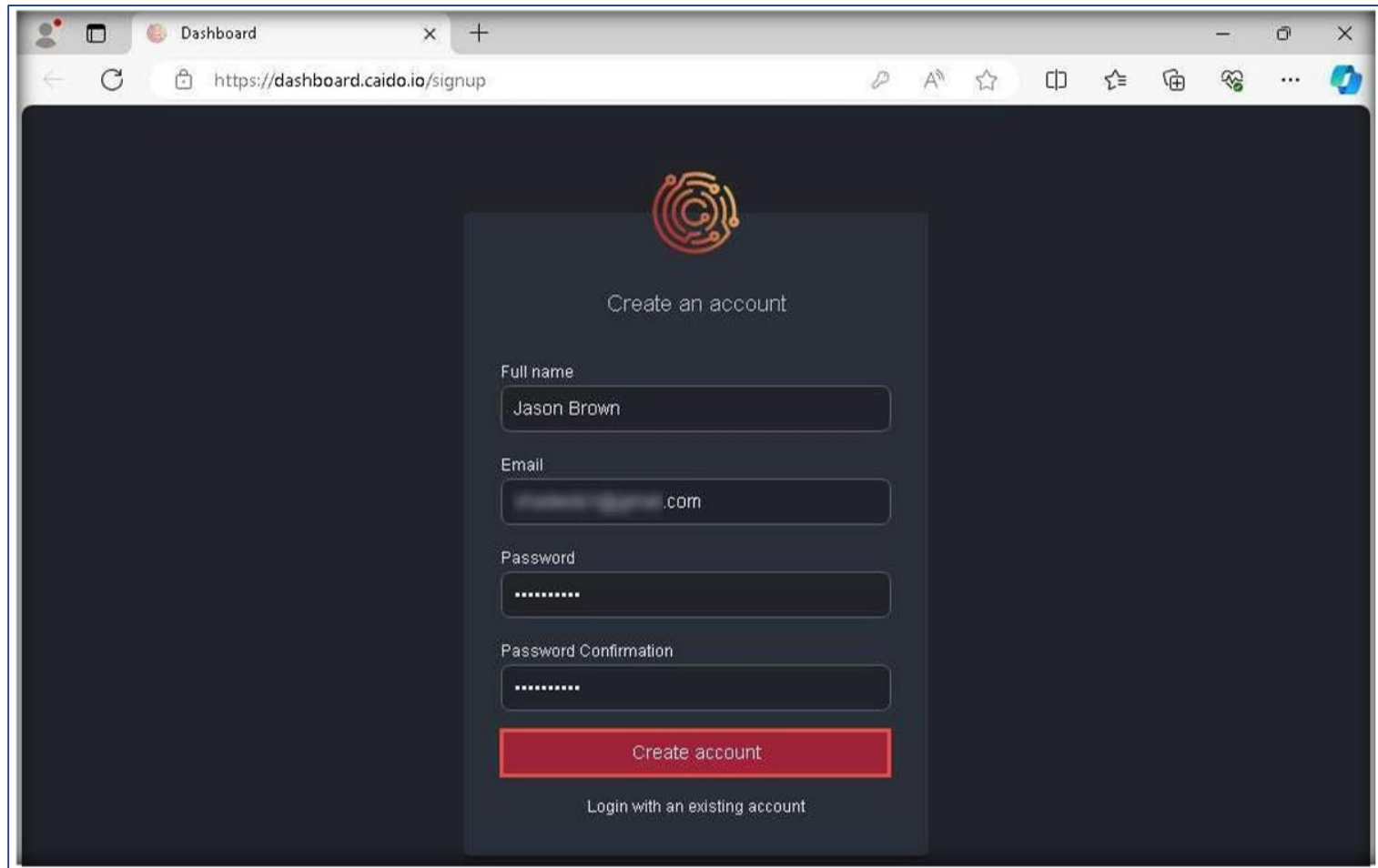
Download logs

Delete Save

START LOCAL INSTANCE

8. Click on **Start** button to start the **local instance**.
9. Welcome to Caído pop-up appears, click on **Login** if you have an account already. If not, select Don't have an account?, you will be redirected to Dashboard.
10. Create an account window appears, here fill in the details and click on **Create account**.

CREATE AN ACCOUNT



The screenshot shows a web browser window with the address bar displaying `https://dashboard.caido.io/signup`. The page has a dark theme. At the top center is a logo consisting of concentric orange and red circles with dots. Below the logo, the text "Create an account" is centered. The form contains four input fields: "Full name" with the value "Jason Brown", "Email" with a partially visible value ending in ".com", "Password" with masked characters "*****", and "Password Confirmation" also with masked characters "*****". Below these fields is a red button labeled "Create account". At the bottom of the form, there is a link that says "Login with an existing account".

Dashboard

`https://dashboard.caido.io/signup`

Create an account

Full name

Jason Brown

Email

.....@......com

Password

Password Confirmation

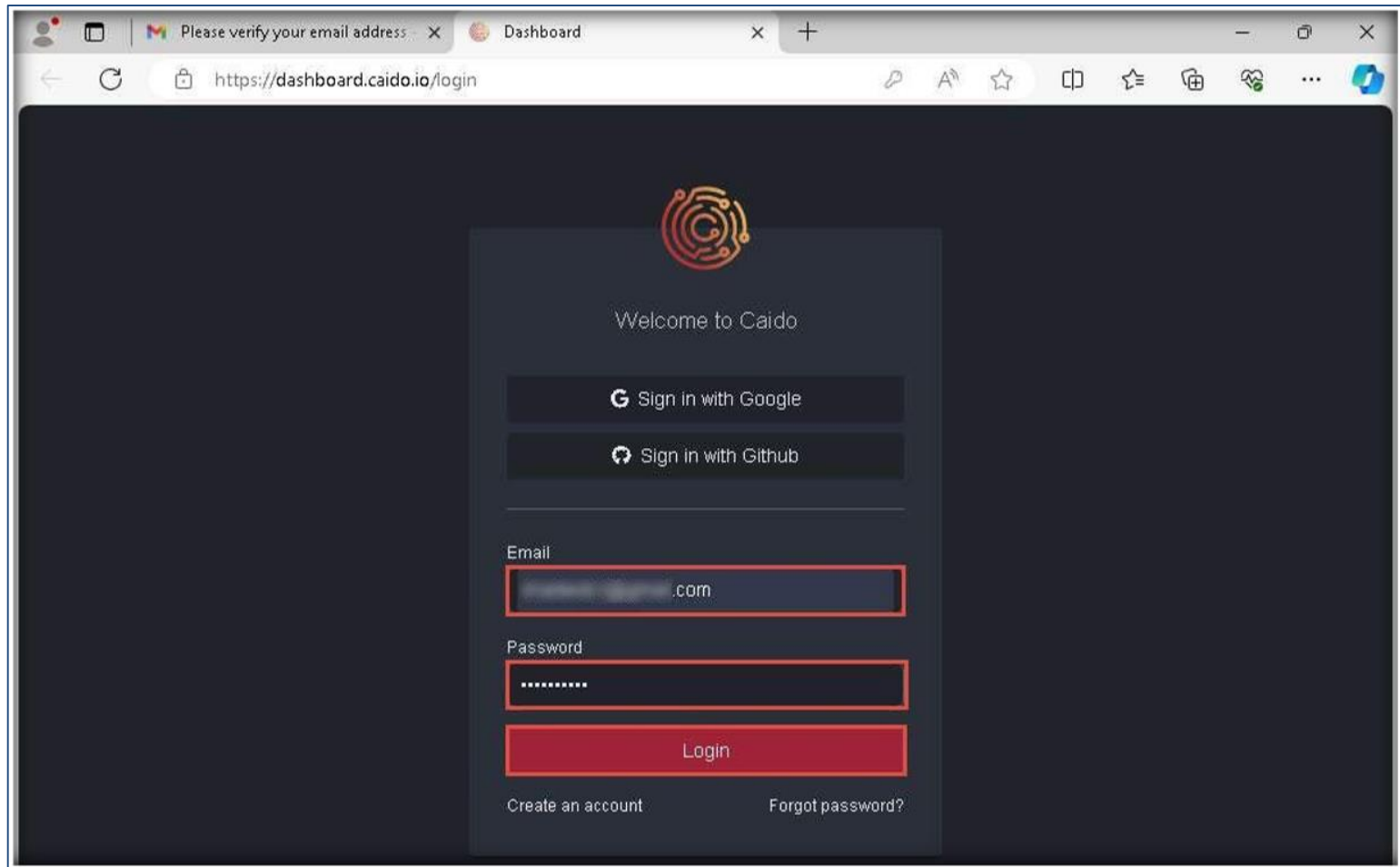
Create account

[Login with an existing account](#)

ACCOUNT ACTIVATION

11. Login to your **mail account**, you will receive a verification mail from Team Caido copy the code and paste it in the Caido verification window.
12. After entering the code, your account will be activated.
13. Navigate back to **Caido application**, in Welcome to Caido pop-up click on Login.
14. Welcome to Caido page will appear, enter your **credentials** and click Login.

FIRST LOGIN



The screenshot shows a web browser window with two tabs: 'Please verify your email address...' and 'Dashboard'. The address bar displays 'https://dashboard.caido.io/login'. The page features a dark background with a central login form. At the top of the form is the Caido logo, a stylized orange and yellow circular icon. Below the logo, the text 'Welcome to Caido' is displayed. The login options include 'Sign in with Google' and 'Sign in with Github', both with their respective logos. Below these, there are input fields for 'Email' (containing 'example@gmail.com') and 'Password' (masked with dots). A red 'Login' button is positioned below the password field. At the bottom of the form, there are links for 'Create an account' and 'Forgot password?'. The browser's toolbar shows standard navigation and utility icons.

Please verify your email address... x Dashboard x +

https://dashboard.caido.io/login

Welcome to Caido

Sign in with Google

Sign in with Github

Email

example@gmail.com

Password

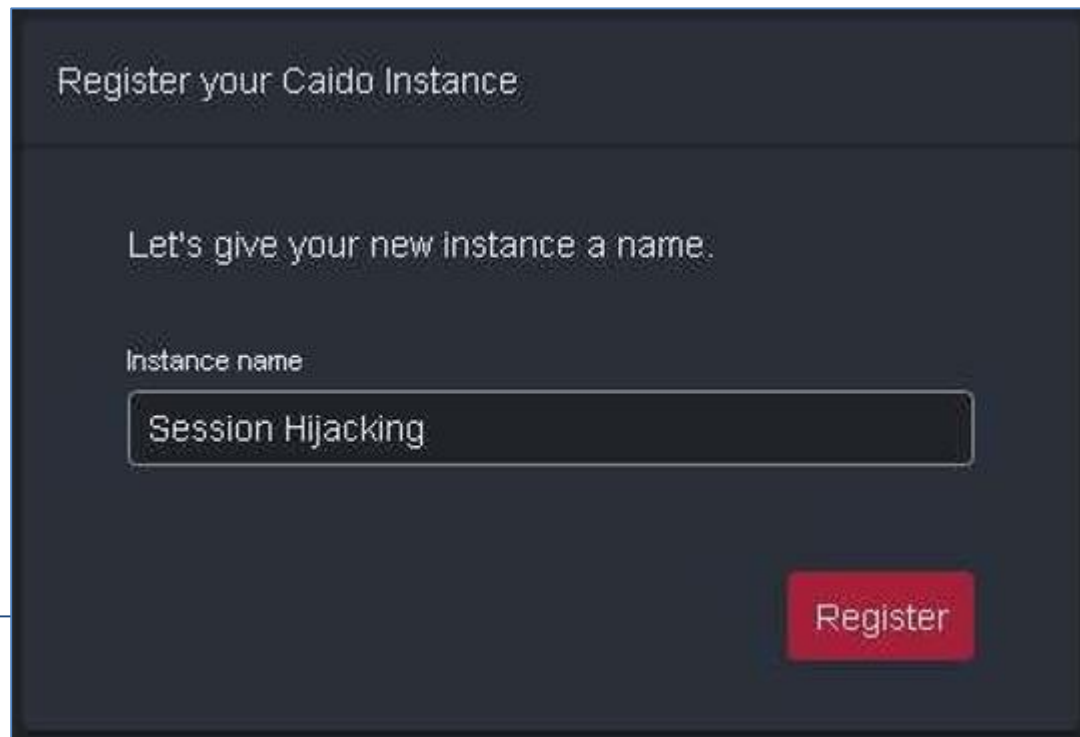
.....

Login

Create an account Forgot password?

INSTANCE REGISTRATION

15. Once logged in, Register your Caido Instance pop-up will appear. Type **Session Hijacking** and click Register.



The image shows a dark-themed pop-up window titled "Register your Caido Instance". Inside the window, there is a prompt "Let's give your new instance a name:" followed by a text input field labeled "Instance name". The input field contains the text "Session Hijacking". At the bottom right of the pop-up, there is a red button with the text "Register".

CAIDO PROJECT

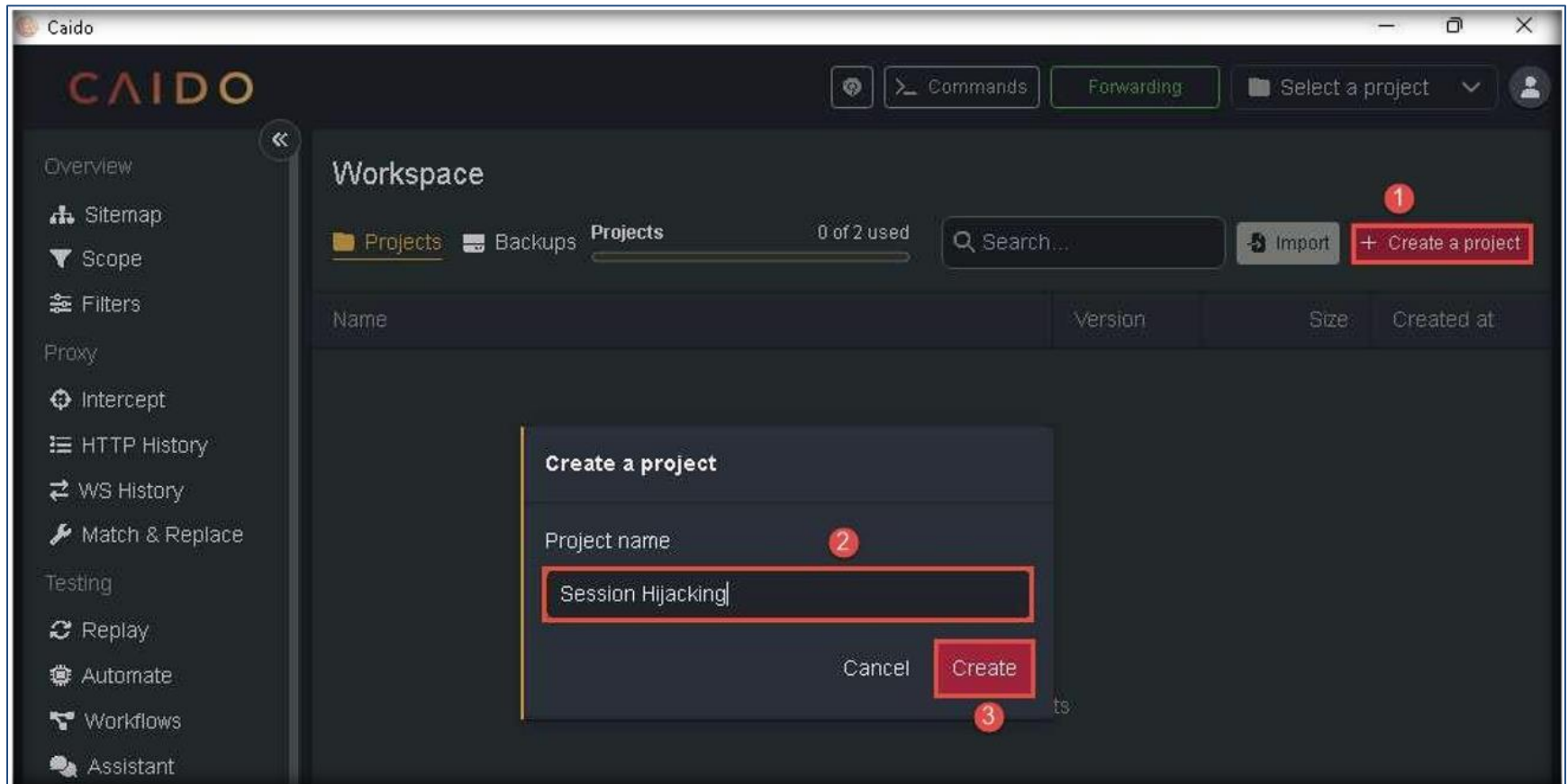
16. Sign in with Caido window appears, click Allow to allow the access. Authorization Complete! pop-up appears, close the web browser and return to the application.

17. The Caido main window appears.

Note: If a Caido pop-up appears, click Next or Ok in all the pop-ups.

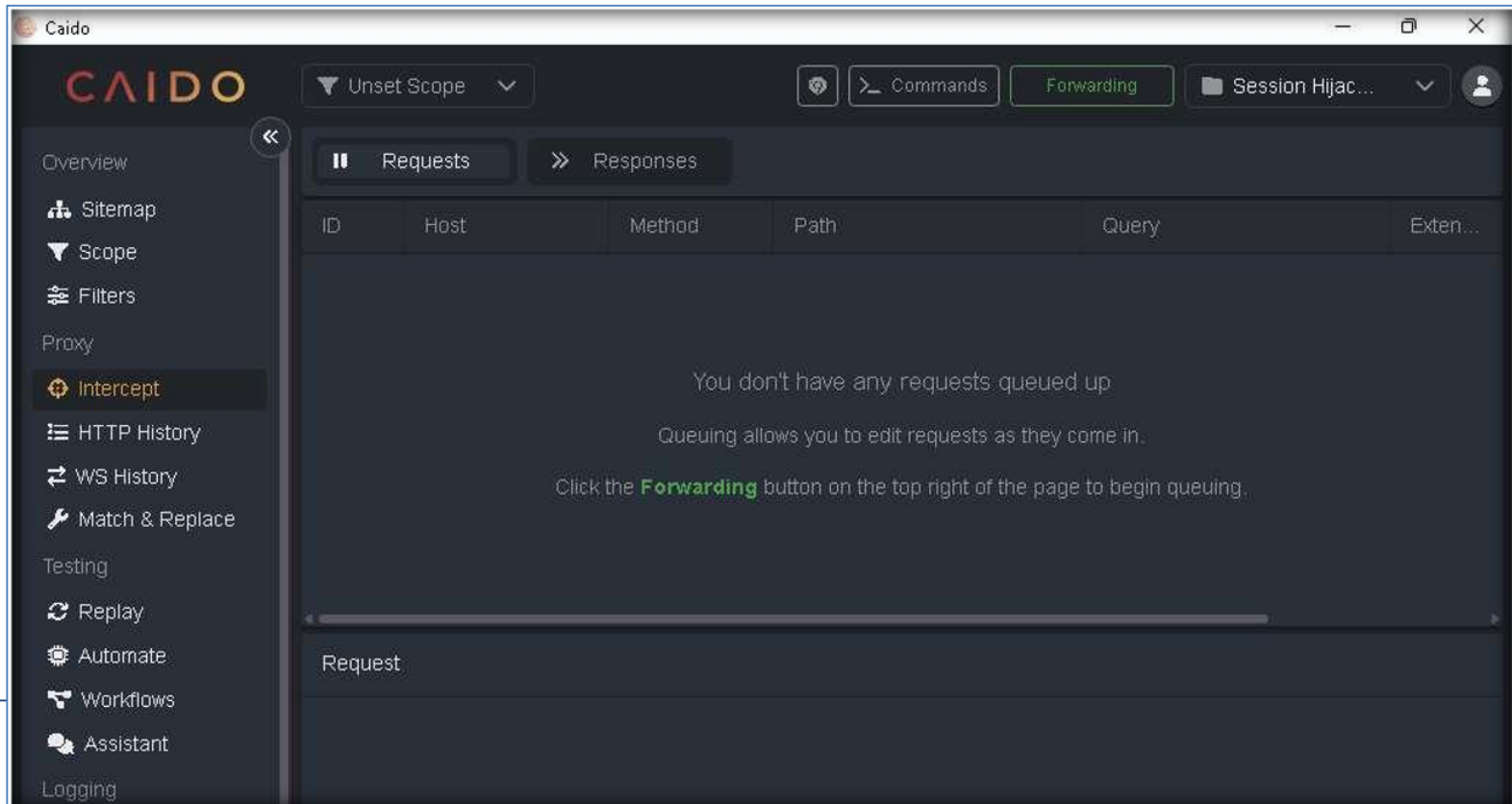
18. Click on + Create a project button to create a new project. Create a project pop-up appears, name it as Session Hijacking and click Create.

CAIDO PROJECT



ACTIVATE INTERCEPTION

19. Click on **Intercept** option on the left pane, as shown in the screenshot below.



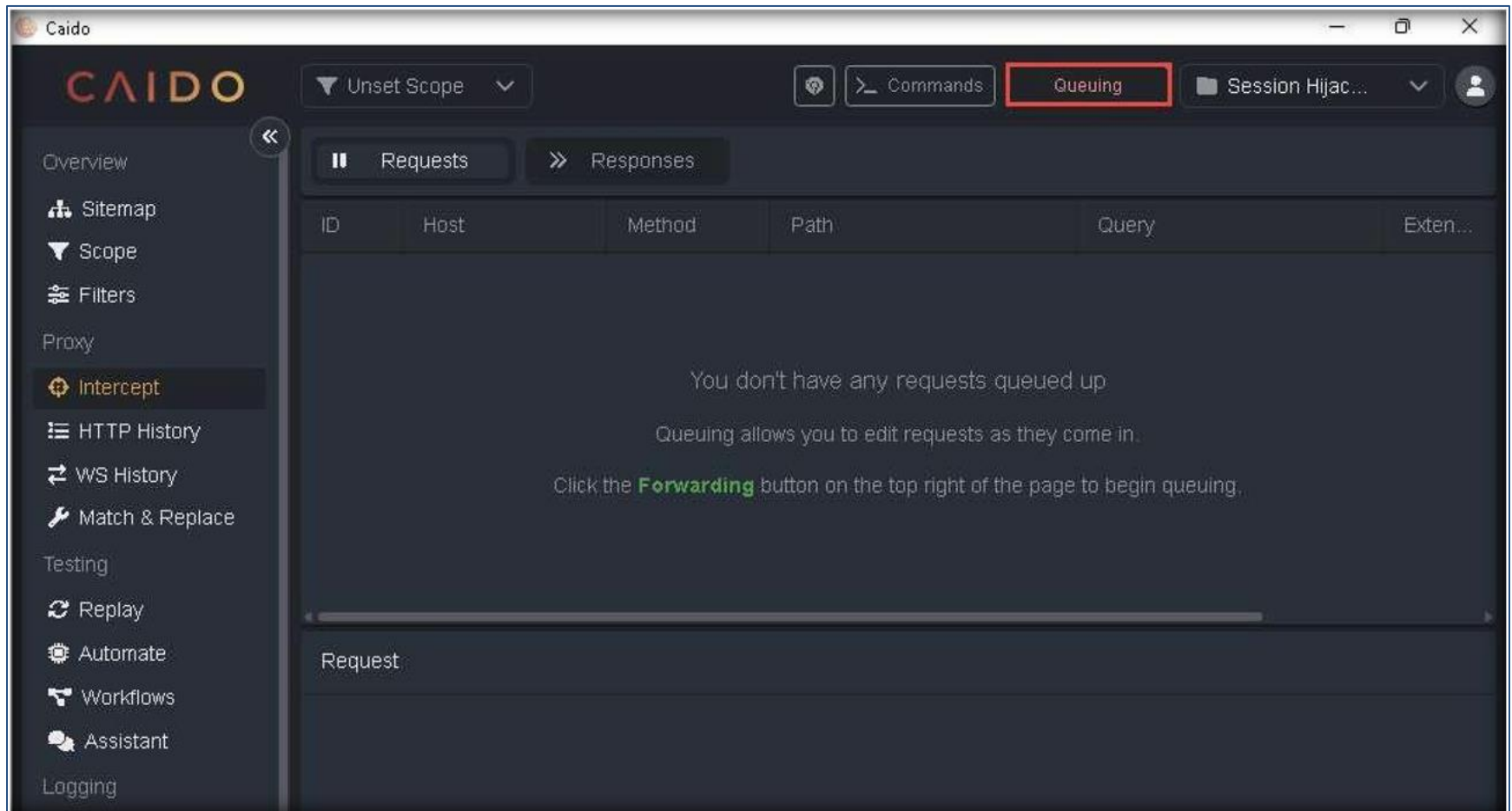
RUN FORWARDING

20. Click the **Forwarding** icon and wait until it changes to **Queuing**.

This button will **trap** and **display** the next **response** or **request** from the **victim's machine** in the **Intercept** tab.

Note: The **Forwarding** icon turns automatically from **green** to **red**.

SEE QUEUING



Switch to Windows Server 2019 VM

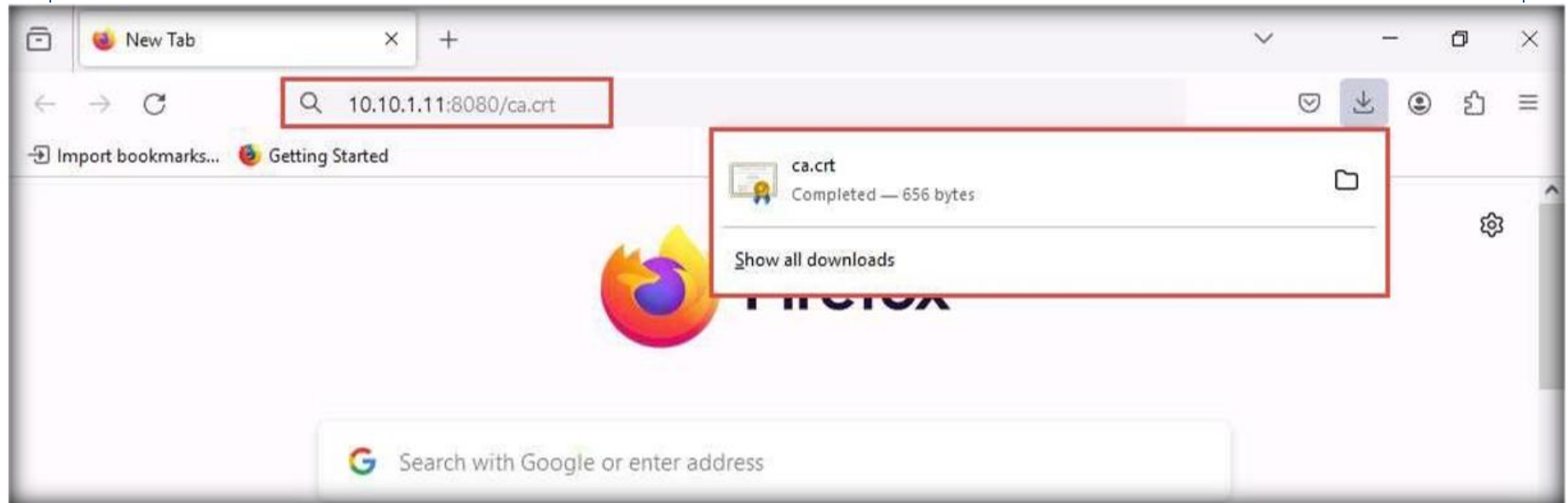
21. Click **Windows Server 2019** to switch to the Windows Server 2019 machine.

Click **Ctrl+Alt+Delete** to activate the machine and login using **Administrator/Pa\$\$w0rd**.

Note: **Networks** screen appears, click **Yes** to allow your PC to be discoverable by other PCs and devices on the network.

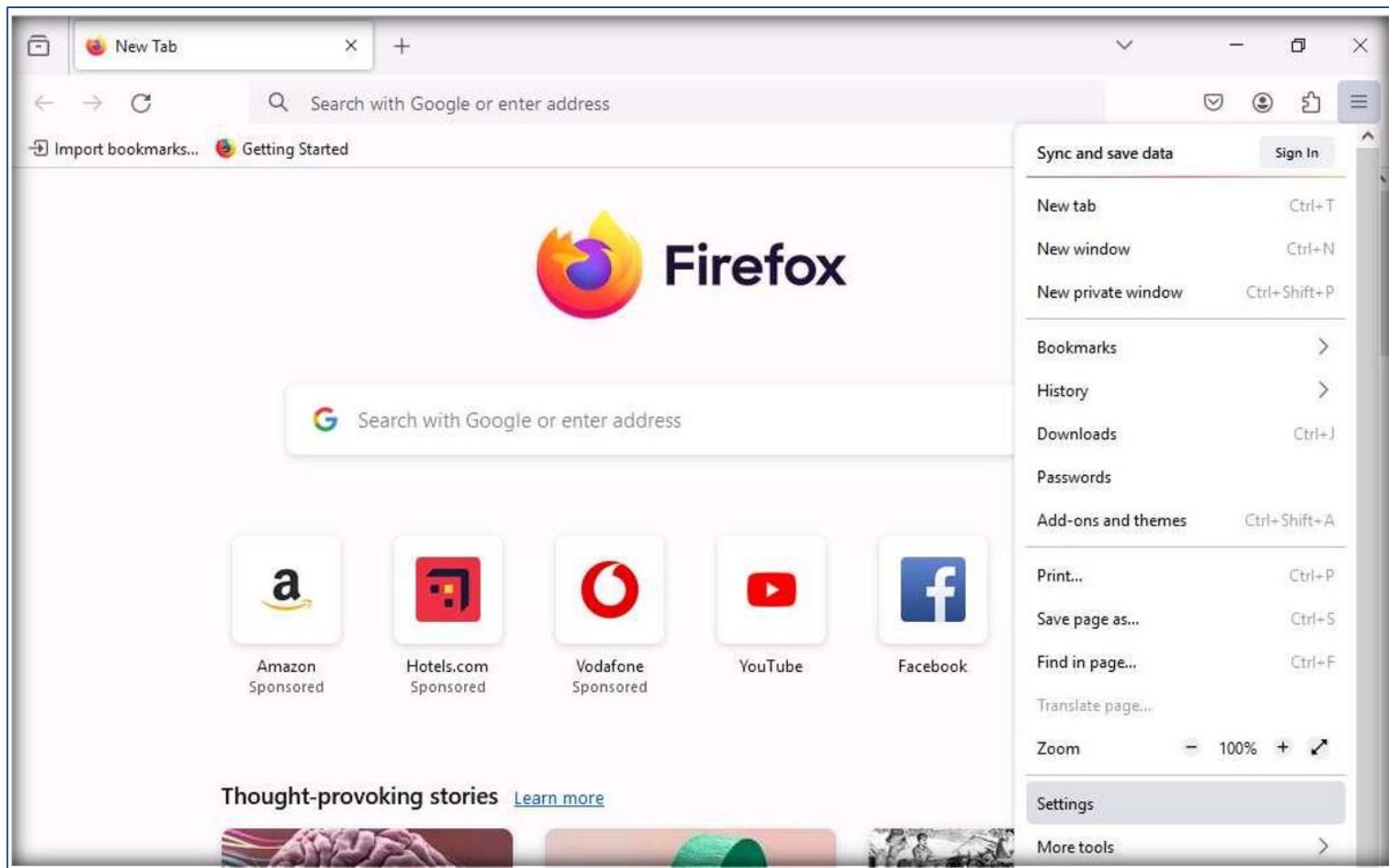
22. Open Firefox web browser and navigate to <http://10.10.1.11:8080/ca.crt> : CA certificate will be downloaded automatically as shown in the screenshot.

Download CA certificate



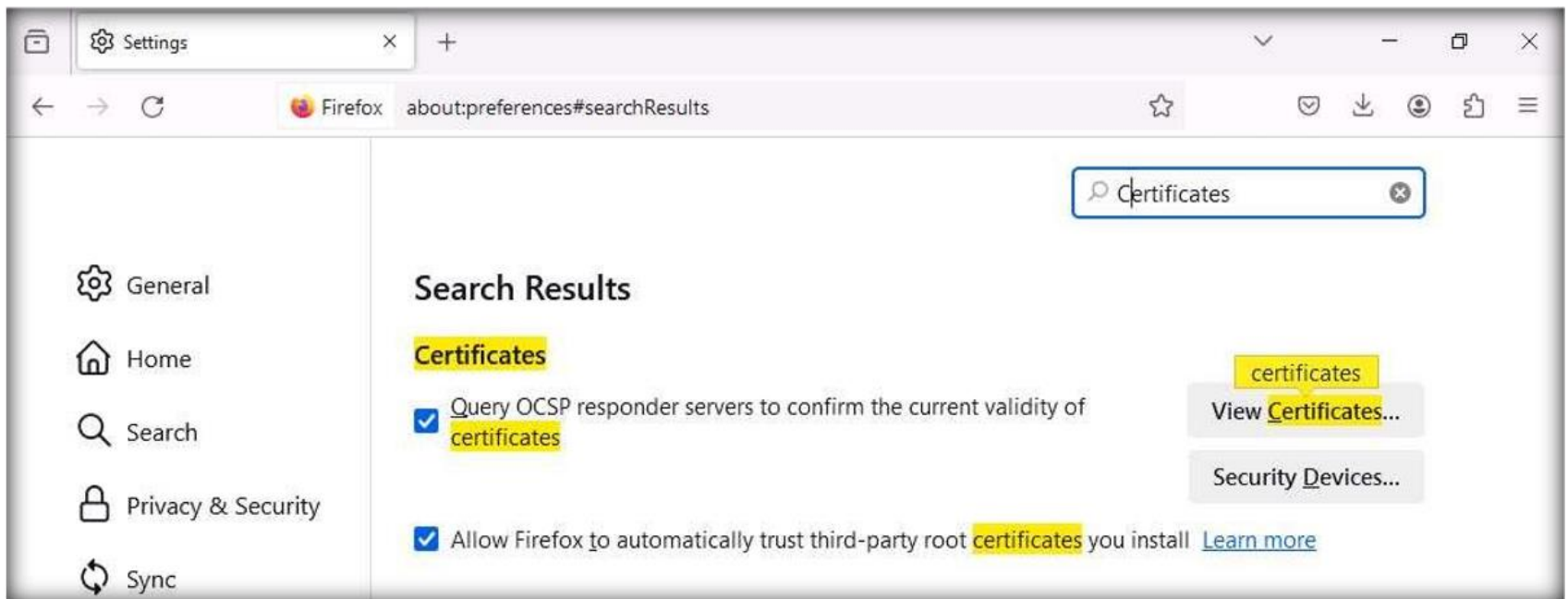
23. In Firefox web browser, select **Settings** from the context menu.

Firefox settings



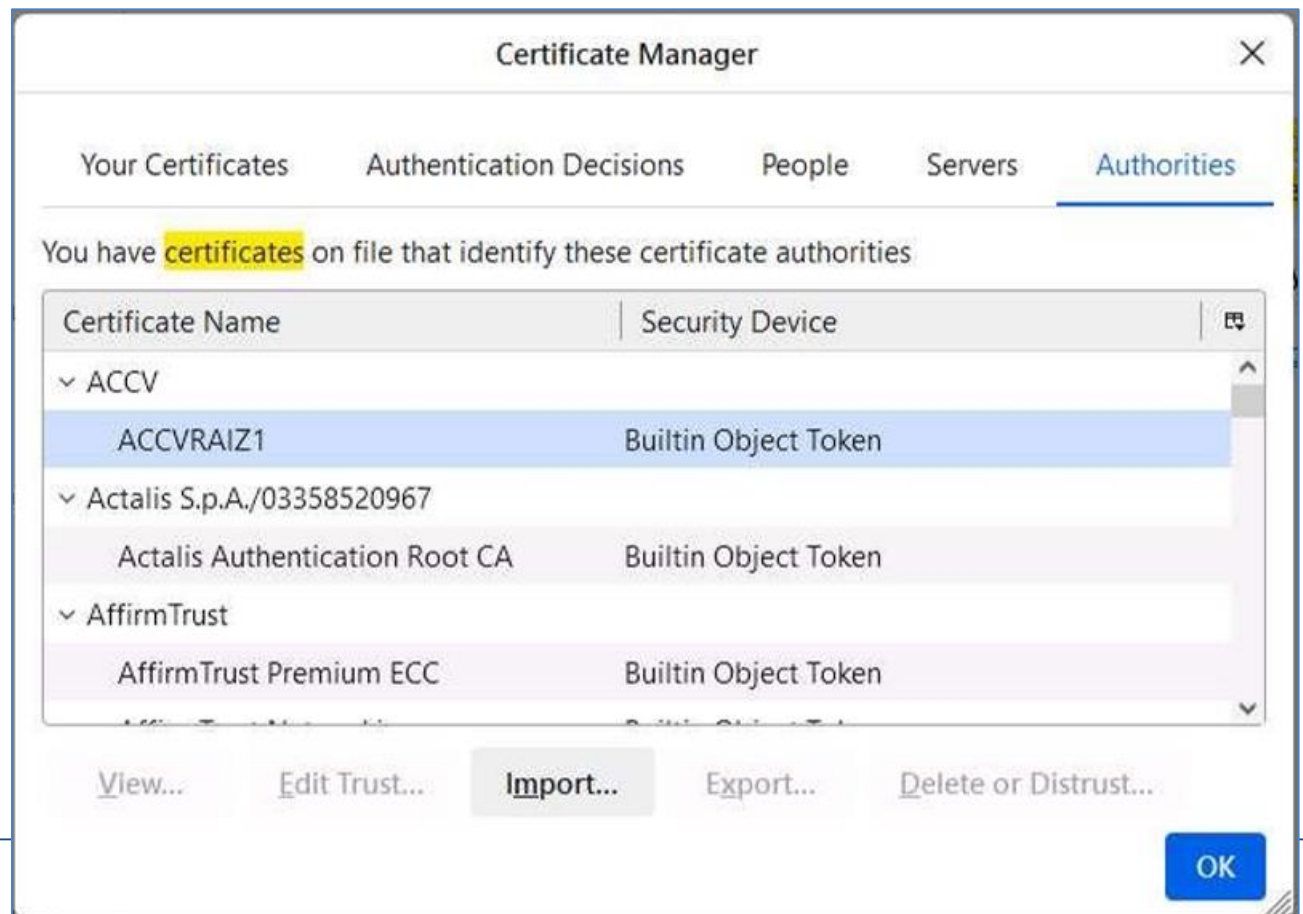
VIEW CERTIFICATES

- 24. On the **Settings** page, search for **Certificates** and open **View Certificates**.



ADD NEW CA

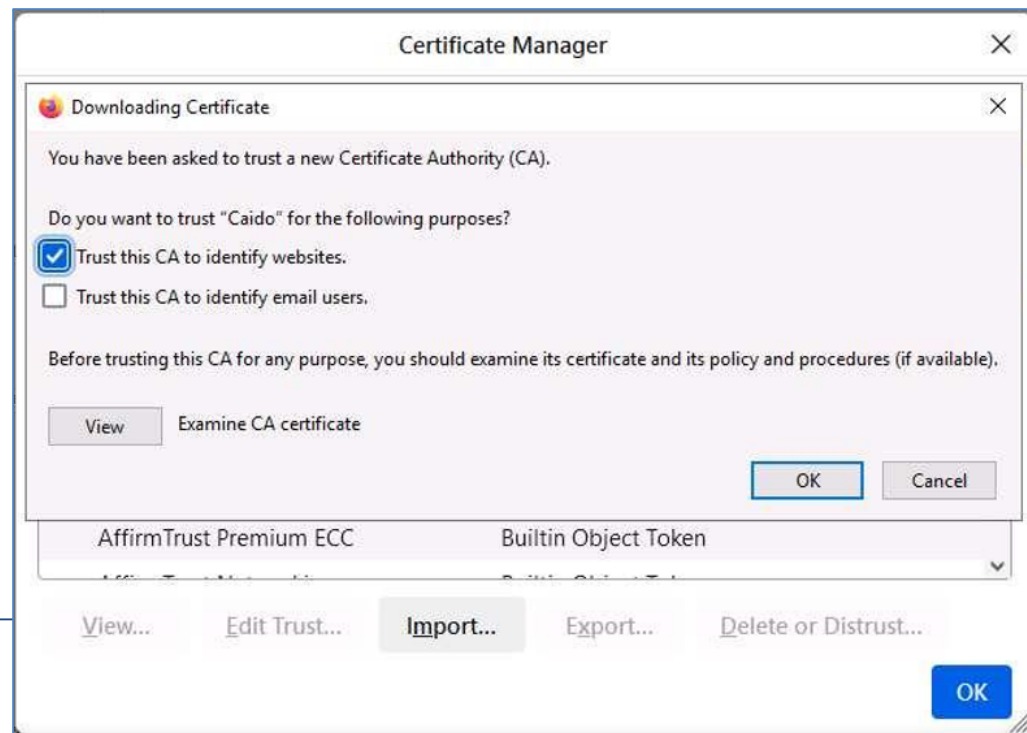
- 25. Navigate to **Authorities** tab and click on **Import...**



IMPORT CA CERTIFICATE

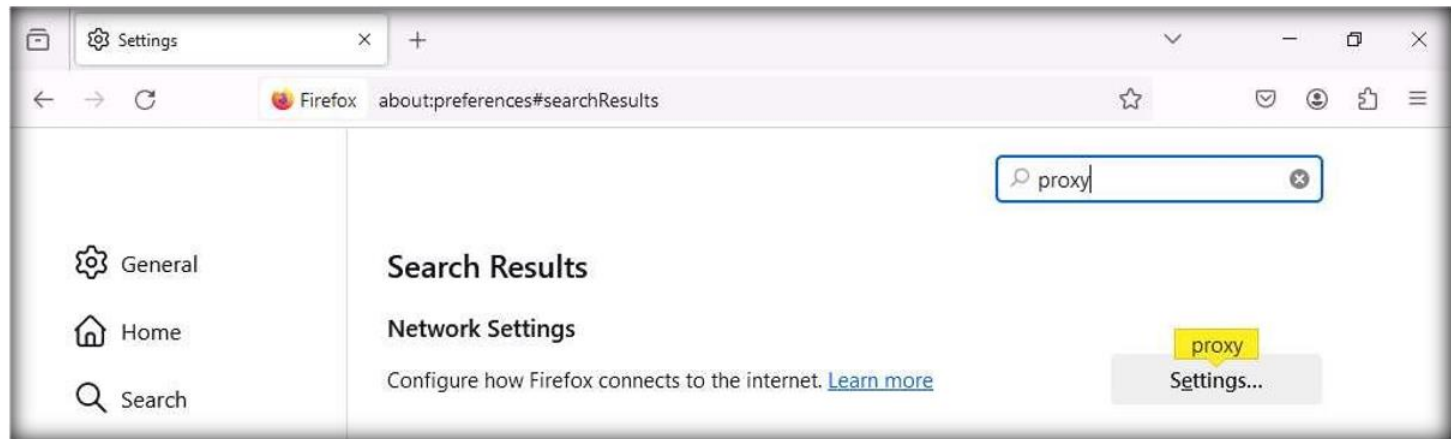
26. In **Select File containing CA certificate(s) to import** window, select the recently downloaded **ca.crt** file and click **Open**.

27. When prompted, click the **Trust this CA** to identify websites checkbox and click on **OK**. Click **OK** in the Certificate Manager window.



CONFIGURE A PROXY

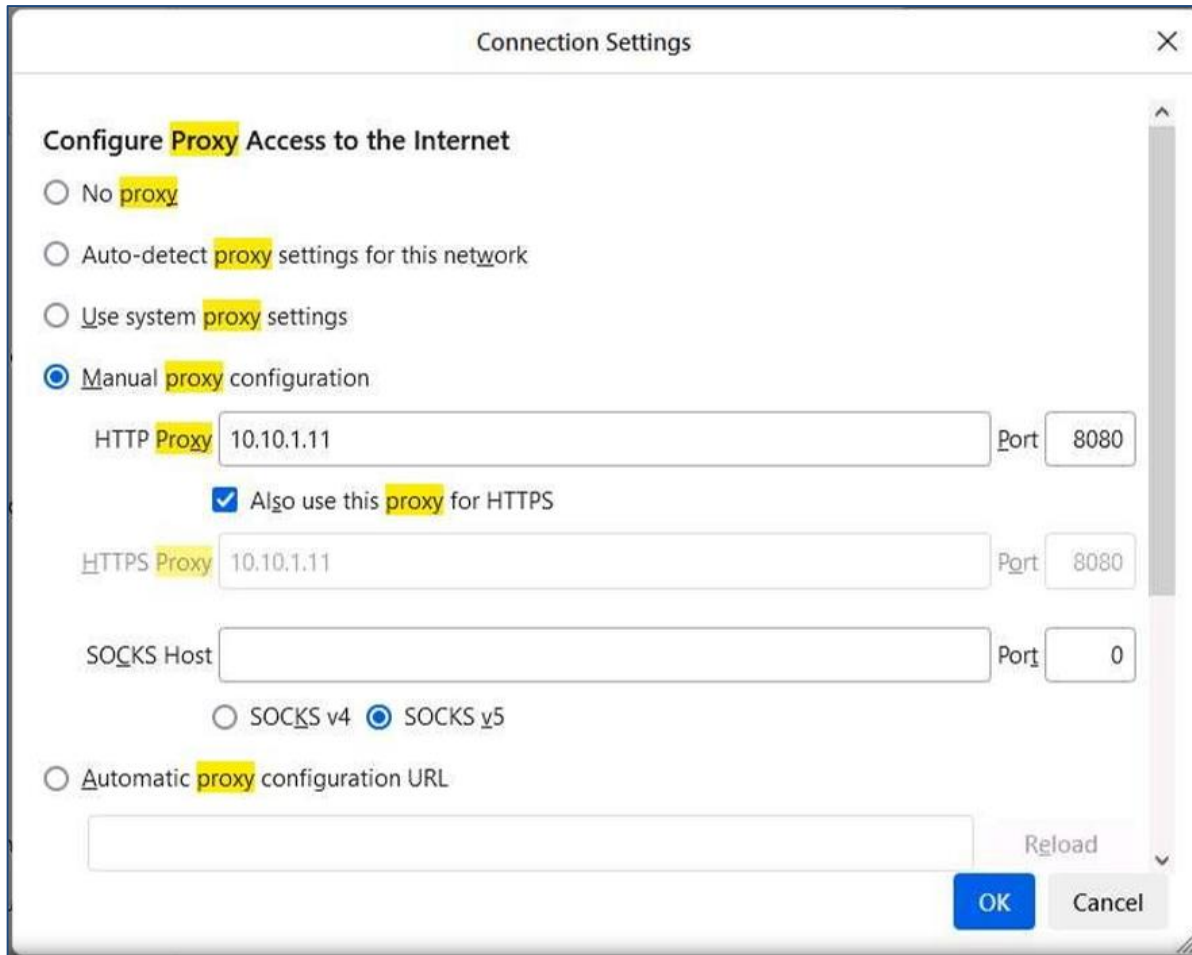
28. On the **Settings** page, search for **proxy** and open it.



29. **Connection Settings** page appears and click **Manual proxy configuration** to configure a **proxy**.

30. Set **HTTP Proxy** to **10.10.1.11** and port to **8080**, check the **Also use this proxy for HTTPS** box and click **OK**.

PROXY MANUAL CONFIGURATION



The screenshot shows a 'Connection Settings' dialog box with a close button (X) in the top right corner. The main heading is 'Configure Proxy Access to the Internet'. There are four radio button options: 'No proxy', 'Auto-detect proxy settings for this network', 'Use system proxy settings', and 'Manual proxy configuration'. The 'Manual proxy configuration' option is selected. Below this, there are three proxy configuration sections. The first is for HTTP, with a text field containing '10.10.1.11' and a 'Port' field containing '8080'. A checked checkbox labeled 'Also use this proxy for HTTPS' is located below the HTTP section. The second section is for HTTPS, with a text field containing '10.10.1.11' and a 'Port' field containing '8080'. The third section is for SOCKS, with a 'SOCKS Host' text field and a 'Port' field containing '0'. Below the SOCKS Host field, there are two radio button options: 'SOCKS v4' and 'SOCKS v5', with 'SOCKS v5' being selected. At the bottom, there is an option for 'Automatic proxy configuration URL' with an empty text field and a 'Reload' button. At the bottom right, there are 'OK' and 'Cancel' buttons.

Connection Settings

Configure Proxy Access to the Internet

☐ No proxy

☐ Auto-detect proxy settings for this network

☐ Use system proxy settings

☒ Manual proxy configuration

HTTP Proxy 10.10.1.11 Port 8080

☒ Also use this proxy for HTTPS

HTTPS Proxy 10.10.1.11 Port 8080

SOCKS Host Port 0

☐ SOCKS v4 ☒ SOCKS v5

☐ Automatic proxy configuration URL

Reload

OK Cancel

OPEN WEBSITE www.moviescope.com

31. After saving, close the Settings and browser windows. You have now configured the proxy settings of the victim's machine.
32. Open a new tab in Firefox web browser and place your mouse cursor in the address bar, type www.moviescope.com and press Enter.
33. If a message appears, stating that Your connection is not private. Click the Advanced button.
34. On the next page, click Proceed to www.moviescope.com (unsafe) to open the website.

CHECK REQUESTS ON CAIDO

- 35. Now, switch back to **Windows 11** machine and observe that **Caido** has begun to capture the **requests** of the victim's machine.
- **Question:** which machine is the victim? 😊

Captured requests

The screenshot displays the CAIDO web application interface. The left sidebar contains navigation options: Overview, Sitemap, Scope, Filters, Proxy, Intercept (highlighted with a red badge showing 38), HTTP History, WS History, Match & Replace, Testing, Replay, Automate, Workflows, Assistant, Logging, Search, Findings, Exports, Workspace, and Files. The main panel is titled 'Requests' and shows a table of captured requests. Below the table, a detailed view of a selected request is shown, including the URL, HTTP method, status code, and headers.

ID	Host	Method	Path	Query	Extension
113	img-getpocket...	GET	/210x109/pixels.format(jpe...		.jpeg
112	img-getpocket...	GET	/218x109/filters.format(jpe...		.jpeg
111	www.moviescop...	GET	/		
110	push.services...	GET	/		
109	detectportal.fir...	GET	/canonical.html		.html
108	www.google.co...	GET	/complete/search	client=firefox&q=ww&chan...	
107	incoming.telem...	POST	/submit/firefox-desktop/us...		
106	detectportal.fir...	GET	/canonical.html		.html
105	detectportal.fir...	GET	/canonical.html		.html
104	incoming.telem...	POST	/submit/firefox-desktop/pa...		
103	detectportal.fir...	GET	/canonical.html		.html
102	detectportal.fir...	GET	/canonical.html		.html

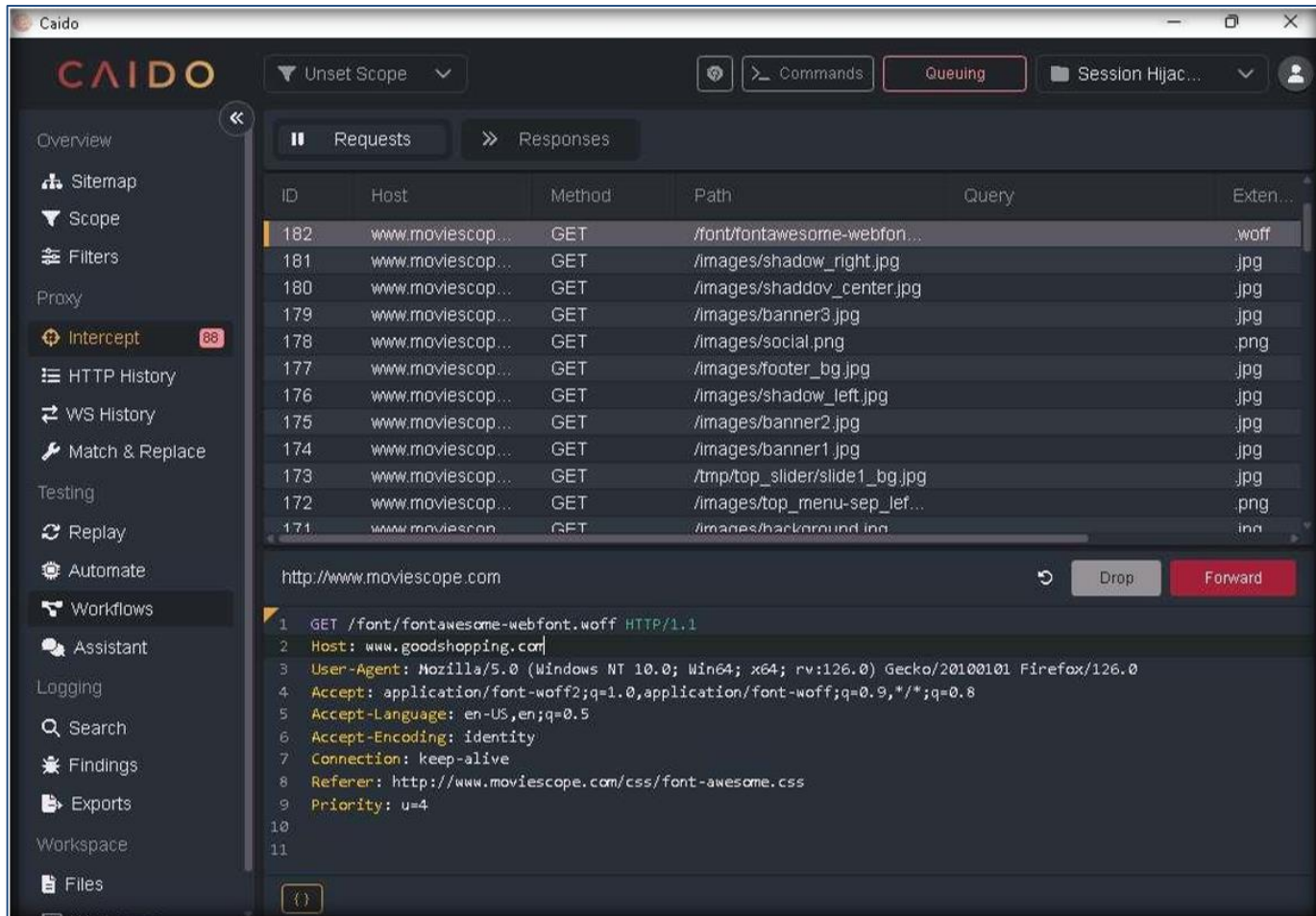
Selected request details for `http://detectportal.firefox.com`:

```
1 GET /canonical.html HTTP/1.1
2 Host: detectportal.firefox.com
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:126.0) Gecko/20100101 Firefox/126.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Cache-Control: no-cache
8 Pragma: no-cache
9 Connection: keep-alive
```

LAUNCHING THE HIJACKING

- 36. On the Requests tab, for all www.moviescope.com requests, modify www.moviescope.com to www.goodshopping.com in all the captured GET requests and Forward all the requests.

Requests Filtering



HIJACKING

37. In a similar way, modify every **GET** request captured by Caido until you see the www.goodshopping.com page in the victim's machine. You will need to **switch back and forth from the victim's machine to see the browser status while you do this.**

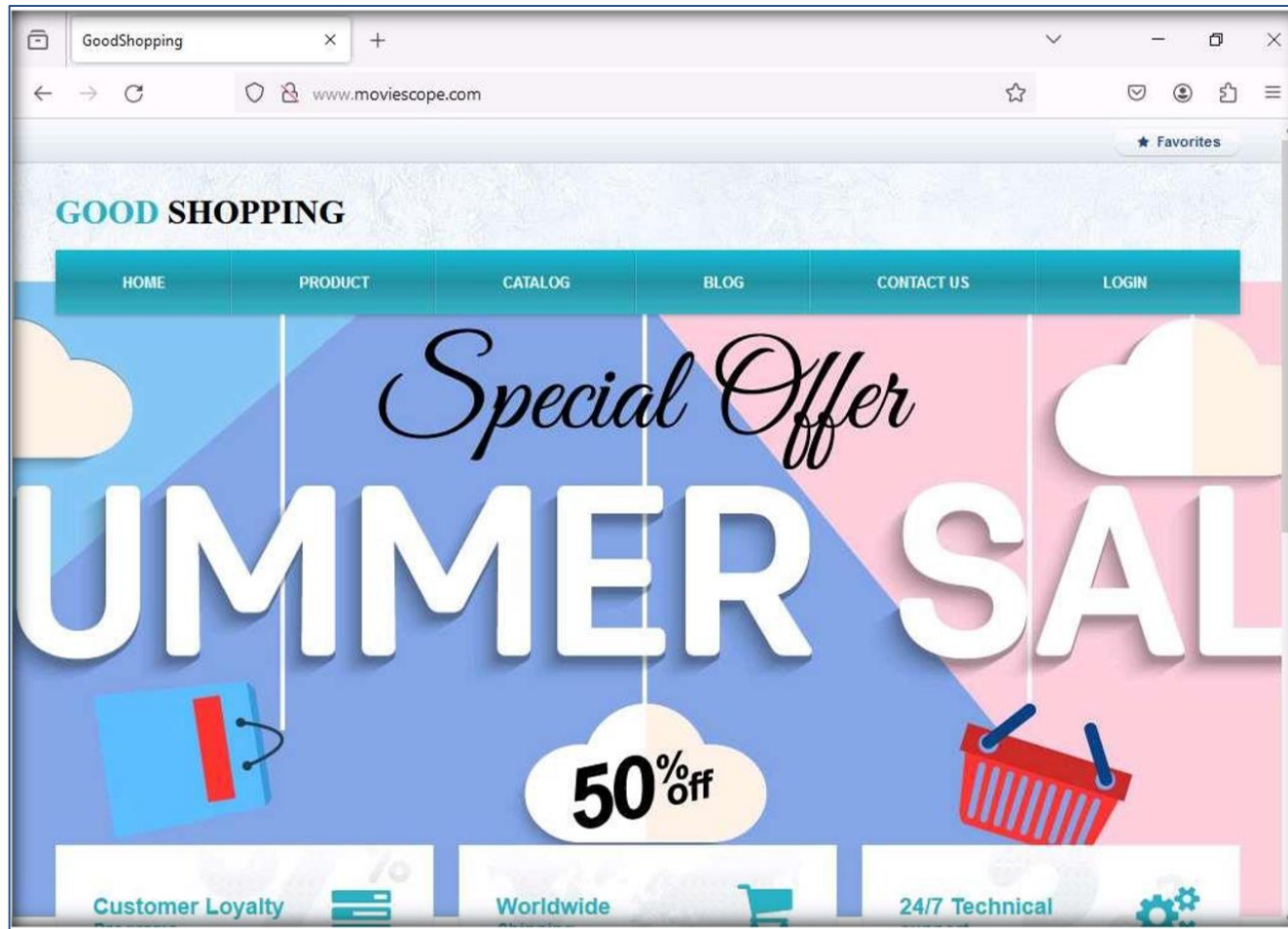
Note: If you do not receive any request or you see a blank Requests tab then switch to Windows Server 2019 machine and **refresh** the browser to capture the request again.

38. Now, click on **Windows Server 2019** to switch to the victim's machine; the browser **displays the website that the attacker wants the victim's machine to see** (www.goodshopping.com).

39. The victim has navigated to www.moviescope.com , but now sees www.goodshopping.com ; while the address bar displays

www.moviescope.com , the window displays www.goodshopping.com

HIJACKED WEBSITE



ENDING THE LAB

40. Now, we shall change the proxy settings back to the default settings.

To do so, in the Firefox browser, select Settings from the context menu. On the Settings page, search for proxy and open it. Connection Settings page appears, check No Proxy radio button and click OK.

41. This concludes the demonstration of performing session hijacking using Caido. 😊

42. Close all open windows and document all the acquired information.

43. Turn off Windows Server 2019 virtual machine.